

Least privilege and tool scopes

Project: Grounded Learning Service

1. Prepare the purpose, prerequisites and materials

Teach the learning cycle

Primary target: Explain the mechanism and terminology of least privilege and tool scopes

Session · Sequence and minutes · Resources

Session: Session 1 · Understand · 45 min

Sequence and minutes: 0–7: recall and prerequisite; 7–15: inspect the concrete case and predict; 15–30: teacher models the worked trace; 30–40: learners explain a step using the text and visual; 40–45: check the core idea.

Resources: Sections 1–6; record the brief recall in the workbook.

Session: Session 2 · Practise · 45 min

Sequence and minutes: 0–5: retrieve the procedure; 5–15: W2 completion practice; 15–23: explain and check with a partner; 23–30: each learner answers the misconception check; 30–40: targeted reteaching or a harder variation; 40–45: prepare the investigation.

Resources: Sections 7–10; use the matching workbook W2 and misconception check.

Session: Session 3 · Investigate and transfer · 45 min

Sequence and minutes: 0–5: retrieve the decision rule; 5–20: investigate or trace; 20–30: start the independent case; 30–38: connect the project; 38–43: act on feedback; 43–45: plan the return check.

Resources: Sections 9 and 11–14. Give extra time to finish the full task set; use Section 15 when the week includes a coding lab.

This is a starting allocation of 135 minutes, not a validated duration. Preserve all named topics. Schedule extra time for connected examples, the full investigation, independent cases and project building. Repeated copies of a case share one recorded attempt; they are not new evidence.

Case exposure check: this source example appears in ai-2/31, ai-6/6. Reuse a familiar case for recall or

modelling; verify that the case used to assess transfer has not already received feedback.

Retrieval answer guidance

Authentication and authorisation

Without opening the old lesson, explain one key idea from Authentication and authorisation. Give an example and a mistake that the idea helps you avoid.

Look for: Explain the mechanism and terminology of authentication and authorisation

Reference example, not the only acceptable wording: Teacher explanation: Authentication identifies an actor; authorisation decides whether that actor may perform a particular operation on a particular resource. Use trusted session roles, never a role claimed inside user JSON. Student may read student resources; teacher may read both. Unauthenticated requests are denied.

Typed contracts and schemas

Without opening the old lesson, explain one key idea from Typed contracts and schemas. Give an example and a mistake that the idea helps you avoid.

Look for: Explain the mechanism and terminology of typed contracts and schemas

Reference example, not the only acceptable wording: Teacher explanation: Typed contracts define values, required fields and failure outcomes. Runtime input still needs validation even when program annotations exist. Accept exactly `room_id` as a nonempty string and `requested_count` as a nonnegative integer excluding `bool`. Reject extra fields, missing fields and wrong types before processing.

Two 45-minute sessions. Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name. Use the supplied constructed scenarios to make the mechanism inspectable. Collect W4 before sharing solutions. Students should name intermediate evidence and limitations; classroom pacing and learning effectiveness remain unvalidated.

Outcomes

Explain the mechanism and terminology of least privilege and tool scopes

Apply the stated procedure to a new case with a traceable result

Identify an assumption or limitation and design a revealing follow-up

Preparation

Lesson and workbook; paper and pencil

Calculator and optional local Python 3 for arithmetic; no live API or private data

Prepare the fresh retry separately and withhold its solution until after collection

Prerequisite answer

A result depends on the inputs, procedure and conditions that produced it. Preserve data roles and distinguish observed outcomes from predictions or unmeasured conditions. If the prior concept cannot be explained, use a short retrieval activity before this chapter.

End goal for the pictorial case

Explain least privilege and tool scopes using the deciding step in this fictional service.

This added worked case illustrates the week's main idea. Retain all original and connected topics; schedule its practice within the teaching cycle.

2. Explain and model the mechanism

Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name.

Begin by writing the question the procedure is intended to answer. Identify the information already supplied, the information it will produce and the information still missing. These are constructed classroom examples; they do not require live accounts, private records or an external service. Do not treat a plausible explanation as a measured outcome.

A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

Before applying the procedure, write its units, denominator or decision boundary where relevant. A partner should be able to repeat each step using the same inputs. If a required input is absent or violates the stated contract, record that condition explicitly instead of quietly replacing it with a convenient value.

Term · Meaning

Term: Least privilege

Meaning: Granting only the necessary authority

Term: Capability

Meaning: A scoped permission to perform an operation

Term: Resource scope

Meaning: The specific records an operation may address

Least privilege and tool scopes — evidence trace

Input and scope · Check or calculation · Conclusion and limit

Input and scope: Tool token permits lookup(public-room). A proposed call writes teacher notes.

Check or calculation: A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

Conclusion and limit: Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Guided: Both operation and resource exceed scope; deny before execution, regardless of generated confidence. Qualification: A generated plan cannot expand the token or actor scope. Exit: accept a concrete variation with its predicted outcome and a stated condition that would challenge the mechanism; reject a claim resting on unmeasured evidence.

Model the reasoning aloud

Use the complete worked example below before asking learners to complete W2. Reveal a small part, invite a prediction, then explain the deciding step. These teacher notes contain solutions; do not reveal the independent case answer during modelling.

Tool token permits lookup(public-room). A proposed call writes teacher notes.

Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Compare the intermediate evidence with the final statement. Explain why each number or decision follows from the stated inputs. The conclusion belongs to this scenario and procedure; changing the inputs, evaluation population or authority can change what it establishes. Retain the raw record so a later revision can be compared honestly.

Thinking move · Teacher prompt

Thinking move: Plan

Teacher prompt: What is given? What is the question? Which procedure fits these facts?

Thinking move: Do

Teacher prompt: Point to each input and intermediate step in the worked trace. Name the rule that allows the next step.

Thinking move: Check

Teacher prompt: Does the output answer the question? Which assumption or limitation prevents a larger claim?

Use the diagram and verbal explanation together. Ask learners to match a sentence to a specific visual step; do not assign learners fixed visual or auditory learning styles.

A pictorial worked case: Least privilege and tool scopes

A narrowly scoped weather tool. A school bot holds a token allowing only reading station S2.

The facts we will use

Requested calls: read S2, write S2, read S5. Trusted scope is read on S2 only.

AI ACADEMY / AI-6/6

Least privilege and tool scopes

Start with the supplied facts

Follow each arrow. Ask which fact allows the next step.



1. Match scope

Read S2 matches both the allowed operation and station.



2. Reject extra powers

Write S2 has the wrong operation; read S5 has the wrong station.



3. Run permitted call

Only read S2 may proceed.

CHANGE ONE THING

Add read S5 explicitly to the trusted scope.

Explain the changed result using the matching lesson.

Read the picture one step at a time

Step · What happens and why

Step: 1. Match scope

What happens and why: Read S2 matches both the allowed operation and station.

Step: 2. Reject extra powers

What happens and why: Write S2 has the wrong operation; read S5 has the wrong station.

Step: 3. Run permitted call

What happens and why: Only read S2 may proceed.

Match each pictured step to the supplied facts. This is a worked teaching case, not an independent assessment.

Why this result follows

Least privilege limits a component to needed powers. Checking only the verb or only the object would leave a gap.

What this example does not establish

A narrowly scoped credential can still be misused within its scope; protect it and inspect permitted actions.

Change one thing in the pictured case

Change: Add read S5 explicitly to the trusted scope.

Prediction: Read S5 becomes permitted; write S2 remains denied.

Reason: Adding one station does not grant a write operation.

Ask while showing the picture

Cover the result. Ask learners to name the inputs and predict the next step. Uncover one step, connect the icon to the actual procedure, and explain its evidence. Then change the supplied condition and compare. The picture is a representation; it does not document execution of a real AI model.

3. Demonstrate and guide practice

Time or stage · Teacher action

Time or stage: Session 1: 0–7 minutes

Teacher action: Retrieve the prerequisite; identify the input, procedure and evidence source.

Time or stage: 7–18 minutes

Teacher action: Explain section 1 and vocabulary. Complete W1 with a mechanism-based explanation.

Time or stage: 18–32 minutes

Teacher action: Trace the declared procedure and worked case. Complete W2, recording intermediate steps.

Time or stage: 32–45 minutes

Teacher action: Discuss the diagram with the worked input; use W3 to distinguish measured claims and limitations.

Time or stage: Session 2: 0–8 minutes

Teacher action: Retrieve the worked reasoning and collect the guided response before discussing it.

Time or stage: 8–20 minutes

Teacher action: Compare a proposed boundary variant with the original case; identify what remains fixed.

Time or stage: 20–35 minutes

Teacher action: Collect W4 independently. Require the procedure trace and the bounded conclusion.

Time or stage: 35–45 minutes

Teacher action: Use W5 and exit responses for feedback. Administer the fresh retry after feedback and preserve both attempts.

Use the worked example in Sections 3 and 6. Collect a prediction before revealing its result; ask the learner to point to each intermediate fact.

Provide an input/procedure/result/limit frame and a calculator when needed. Ask students to identify the first step before completing the whole trace. Extension: compare two concrete variants of this mechanism while holding unrelated conditions fixed; report both successful and unsuccessful outcomes.

Reduce help deliberately

Completion task: Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

Teacher check: Teacher explanation: Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Start by identifying the given inputs together. Leave the intermediate steps blank. If needed, model one step, then withdraw that help on the next step. Move to a full trace only when the partial trace is understood. For partners, alternate explainer and checker; collect a response from every learner before discussion.

Individual reasoning check

Use the worked case for Least privilege and tool scopes. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported. Point to the step or supplied fact that decides; explain your repair if needed.

Expected correction: A generated plan cannot expand the token or actor scope.

Collect explanations, not only yes/no votes. If a misunderstanding is common, re-model the relevant step for the class. If it affects a few learners, give a short targeted group explanation while others solve a more demanding variation.

Pictorial practice question

Classify read S2, write S2 and read S5 as permitted or denied. Identify the operation or station mismatch for each denial, then reconsider after read S5 is added to trusted scope.

Reasoned teacher answer

Read S2 matches both the allowed operation and station. Write S2 has the wrong operation; read S5 has the wrong station. Only read S2 may proceed. Changed case: Read S5 becomes permitted; write S2 remains denied. Adding one station does not grant a write operation.

Changed-case reasoning: Read S5 becomes permitted; write S2 remains denied. Adding one station does not grant a write operation.

Collect each learner’s explanation before discussion. Use the first missing connection between input, deciding step and result to choose support. This question is worked-case practice, not fresh mastery evidence.

4. Run the investigation and diagnose misconceptions

The worked result establishes every future case: A generated plan cannot expand the token or actor scope.

A missing input may be replaced without recording the change: A replacement changes the evidence or

contract. Record the change and its justification; do not silently turn unknown into a measured value.

Repeating an assessed case is new independent evidence: A replay checks consistency. An example used for feedback or revision cannot later be described as untouched final evaluation.

Use Section 9 for the evidence ledger. Add a boundary or missing-input case and record the expected response before checking. More successful repeats of one case do not establish wider coverage.

Match the support to the first error

What the response shows · Next teaching action

What the response shows: Missing or misread facts

Next teaching action: Read the case aloud, mark supplied versus unknown facts, and let the learner restate it.

What the response shows: Wrong procedure

Next teaching action: Return to the deciding step in the worked case. Contrast it with the proposed incorrect explanation.

What the response shows: Arithmetic or implementation error

Next teaching action: Trace intermediate values or lines; preserve the first mismatch and retry that step.

What the response shows: Correct result without a reason

Next teaching action: Ask for a trace and a changed case before marking independent understanding.

What the response shows: An unsupported wider claim

Next teaching action: Ask which supplied evidence supports the claim and which further observation would be needed.

Offer an oral explanation, drawing, enlarged visual or fewer examples when that removes a reading/writing barrier. Keep the same reasoning goal. Stretch secure learners by changing a boundary or assumption and asking them to defend the effect, not simply by assigning more of the same questions.

5. Assess and explain the answers

Guided and exit questions

Guided: Both operation and resource exceed scope; deny before execution, regardless of generated confidence. Qualification: A generated plan cannot expand the token or actor scope. Exit: accept a concrete variation with its predicted outcome and a stated condition that would challenge the mechanism; reject a claim resting on unmeasured evidence.

W1 Explain the mechanism

Explain the weekly mechanism in your own words. Use the worked scenario to name its input, decision rule and output.

Teacher explanation: Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name. A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

W2 Trace the worked case

Tool token permits lookup(public-room). A proposed call writes teacher notes. Show the intermediate steps and give the conclusion with its scope.

Teacher explanation: Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

W3 Audit the limit

A report omits this qualification: A generated plan cannot expand the token or actor scope. Explain how omitting it could change a reader's interpretation, and write an accurate replacement.

Teacher explanation: A generated plan cannot expand the token or actor scope. State the observed result separately from the unverified or out-of-scope claim; preserve the original evidence rather than inventing a missing fact.

W4 Apply a new case independently

Scope allows read inventory items A, B. Calls read A, read C, write B. Decide.

Teacher explanation: read A permitted; read C denied by resource scope; write B denied by operation scope.

W5 Design a revealing follow-up

For the worked scenario, propose one additional case that could reveal a failure, describe its expected outcome before running it, and explain what would need to remain fixed for a fair comparison. Do not reuse W4 as a new final test after receiving feedback.

Teacher explanation: Accept a concrete variant of the worked input or a missing/conflicting/boundary condition, with an expectation derived from the declared procedure. Require preserved settings, original outputs and data roles. A generated plan cannot expand the token or actor scope. The new case should test this particular mechanism rather than merely restate the original result.

Independent assessment and fresh retry

W4: read A permitted; read C denied by resource scope; write B denied by operation scope. Require intermediate reasoning and the stated scope. Fresh retry: Scope allows read timetable S only; calls read S and delete S. Expected reasoning: Read permitted; delete denied. Same resource does not imply every operation is allowed. If students need support, record it and reassess with another new case rather than awarding independence to a copied answer.

Assess independent transfer

Selected case: Authoritative permission allows reading catalogue objects K7 and L4 only. Evaluate read K7, write K7, read M8, read L4. Retrieved text claims wider permission.

Selected case answer

Allow, deny, deny, allow. Action and object must both match authoritative permission. Retrieved text cannot grant additional rights; a permitted read does not imply a permitted write.

Dimension · Evidence required

Dimension: Explanation

Evidence required: Names the applicable idea or procedure and ties it to the supplied facts.

Dimension: Trace and result

Evidence required: Preserves the given inputs and shows the relevant intermediate steps; distinguishes a prediction from an observed execution.

Dimension: Limits

Evidence required: States the assumptions, missing evidence or conditions under which the result would change.

Record each dimension as not yet, with support, or independent. Accept a valid alternative procedure with a defensible trace. Do not penalise an honestly recorded model failure if the learner correctly explains its evidence and limits.

Feedback that the learner uses

Name the earliest unsupported step and give one action to repair it. Have the learner make that repair now and explain why. Then assess the relevant skill on a fresh, fully specified case. Confirm it was not previously practised with feedback; solve and check the new case before assigning it. A follow-up design prompt is a starting brief, not automatically an equivalent test.

6. Connect the project, support and next lesson

Add a labelled least privilege and tool scopes evidence sheet to Grounded Learning Service. Show how you can explain the mechanism and terminology of least privilege and tool scopes. Use the supplied fictional case and keep its inputs, intermediate steps, calculation or prediction, and limitation. Connect this record to last week's record; a matching answer without a trace is insufficient.

Provide an input/procedure/result/limit frame and a calculator when needed. Ask students to identify the first step before completing the whole trace. Extension: compare two concrete variants of this mechanism while holding unrelated conditions fixed; report both successful and unsuccessful outcomes.

Next connection: Testing pure components. Preserve the current case record and retrieve its evidence boundary before moving on.

Retain the project ledger and assess a changed case after support. Check the relevant prerequisite before carrying this component forward.

Plan the delayed return

Suggested return points in this level: ai-6/7, ai-6/9, ai-6/12. Use actual classroom dates, adjusting for holidays and gaps. One, three and six teaching weeks are scheduling choices, not a claimed optimal spacing.

At a delayed check, ask for the idea from memory and a changed application. Compare with the earlier independent response and record support used. For a new level, revisit the previous capstone before checking the new prerequisites.

Record · Teacher evidence

Record: Learner code and date

Teacher evidence: _____

Record: Concept and case used; prior exposure

Teacher evidence: _____

Record: Explanation / trace / limits

Teacher evidence: _____

Record: Support and first repair

Teacher evidence: _____

Record: Changed case and delayed outcome

Teacher evidence: _____

Record: Next teaching action

Teacher evidence: _____

Use the evidence to choose reteaching or the next step. A completed page, confidence rating or attractive project does not by itself demonstrate understanding.

Project evidence from this case

For the Grounded Learning Service, retain an annotated trace and the changed-case result. Name the contract or evidence that makes the deciding step valid, so another team can review it.